

CO1

ASSESSMENT TOOL-2

NAME : P. Ranjithkumar

DATE:15.07.2026

REG.NO: 192411119

Wednesday

COURSE CODE : ITA1408

COURSE NAME : Ethical Hacking

1. Unauthorized Nmap Scan on a Company's Network

Introduction

Network scanning is an important activity in cybersecurity to identify open ports, active hosts, and running services. Tools such as **Nmap (Network Mapper)** are commonly used by security professionals during vulnerability assessments. However, performing a network scan on another organization's systems without obtaining prior permission is both an ethical and legal concern.

Ethical Analysis

The student's actions are **unethical** because:

- The student accessed another organization's network without authorization.
- Ethical hacking requires **prior written permission** from the owner of the system.
- Even though no data was stolen or systems were damaged, unauthorized scanning violates professional ethics.
- Ethical hackers must respect **privacy, ownership, and organizational policies**.

Therefore, the student's intention may have been educational, but the method used was not ethically acceptable.

Legal Analysis under the Information Technology (IT) Act, 2000

Although the student did not hack the system, unauthorized network scanning can still attract legal action.

Section 43

This section states that any person who accesses a computer system or network **without permission** may be liable to pay compensation if loss or damage is caused.

The student's scan:

- Accessed the company's network without authorization.
- May have consumed system resources.
- Triggered security alerts.

Section 66

If unauthorized access is performed **dishonestly or fraudulently**, it becomes a criminal offence under Section 66.

In this case:

- The student had no malicious intention.
- No data was modified or stolen.

Section 72

If confidential information had been obtained and disclosed, Section 72 could apply.

In this case:

- No confidential information was accessed.

Hence this section is generally not applicable.

Possible Legal Consequences

The student may face:

- Police investigation by the Cyber Crime Cell.
- Civil liability under Section 43.
- College disciplinary action.
- Damage to professional reputation.
- Difficulty obtaining internships or security-related jobs.

Correct Procedure Before Conducting Security Assessment

The student should have followed these steps:

1. Obtain written permission from the organization.
2. Clearly define the scope of testing.
3. Sign an authorization or engagement agreement.
4. Conduct scanning only within the approved scope.
5. Document findings responsibly.
6. Submit a confidential security report.
7. Never disclose vulnerabilities publicly without permission.

Diagram: Responsible Vulnerability Disclosure

Researcher



Find Vulnerability



Privately Inform Company



Company Fixes Issue

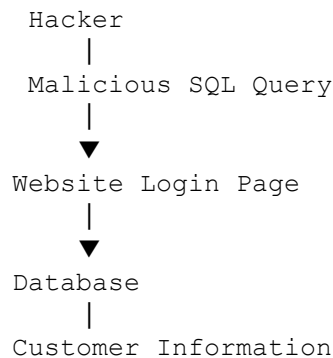


Security Patch Released



Public Disclosure

SQL Injection Attack Diagram



Conclusion

Although the student did not intend to cause harm, unauthorized network scanning is neither ethical nor legally safe. Ethical hacking always requires prior authorization. Following proper legal and professional procedures protects both the organization and the security researcher.

2. Public Disclosure of SQL Injection Vulnerability

Introduction

SQL Injection is one of the most dangerous web application vulnerabilities because it allows attackers to manipulate database queries and potentially access sensitive information. Security researchers play an important role in discovering such vulnerabilities, but they also have a responsibility to disclose them responsibly.

Ethical Analysis

The researcher acted **unethically** because:

- The vulnerability was published before the company had an opportunity to fix it.
- Proof-of-concept (PoC) exploit code was shared publicly.
- This exposed millions of users to unnecessary risk.
- Ethical researchers prioritize protecting users rather than gaining publicity.

The researcher violated the principle of **Responsible Disclosure**.

Responsible Vulnerability Disclosure

Responsible disclosure is a process where:

1. The researcher privately informs the organization.
2. Technical details are shared confidentially.
3. The organization is given reasonable time (usually 30–90 days) to fix the issue.
4. Public disclosure happens only after the vulnerability has been patched or with the organization's agreement.

This approach balances public awareness with user safety.

Risks of Premature Public Disclosure

Publishing the vulnerability immediately can result in:

- Mass exploitation by cybercriminals.
- Theft of customer data.
- Financial losses.
- Identity theft.
- Loss of customer trust.
- Legal consequences.
- Damage to the company's reputation.

In this case, attackers exploited the vulnerability before it was patched.

Legal Perspective

The researcher may face legal consequences if:

- The proof-of-concept involved unauthorized access.
- Customer information was accessed.
- The disclosure facilitated cybercrime.

Possible IT Act provisions include:

Section 43

Unauthorized access to computer systems.

Section 66

Computer-related offences committed dishonestly or fraudulently.

Section 72

Disclosure of confidential information without authorization.

Depending on the circumstances, civil or criminal liability may arise.

Correct Steps the Researcher Should Have Followed

- Verify the vulnerability carefully.
- Avoid accessing customer data unnecessarily.
- Collect only minimal evidence.
- Contact the organization's security team privately.
- Allow sufficient time for remediation.
- Cooperate with developers if required.
- Publish technical details only after the issue is resolved.

Responsible Vulnerability Disclosure

Researcher

|



Find Vulnerability

|



Privately Inform Company

|



Company Fixes Issue

|



Security Patch Released

|



Public Disclosure

SQL Injection Attack Diagram



Conclusion

Cybersecurity research carries ethical responsibilities. Premature disclosure can unintentionally help cybercriminals. Responsible vulnerability disclosure protects users while allowing organizations sufficient time to fix security weaknesses.

3. Employee Falls Victim to Fake IT Support Email

Introduction

Phishing attacks remain one of the most common cybersecurity threats. Attackers trick users into revealing confidential information by pretending to be trusted organizations. Human error often becomes the weakest link in organizational security.

Type of Cyberattack

The attack is a:

Phishing Attack

Specifically, it is a **Credential Phishing Attack** because:

- Fake IT support email.
- Urgent password verification request.
- Fake login page.
- Theft of employee credentials.

The attacker then used these credentials to gain unauthorized access.

Legal Implications under the IT Act, 2000

Section 43

Unauthorized access to company systems.

Section 66

Computer-related offences involving dishonest or fraudulent access.

Section 66C

Identity theft through misuse of login credentials.

Section 66D

Cheating by personation using computer resources.

The attacker impersonated the company's IT support team.

Section 72

If confidential company information is disclosed, this section may also apply.

Responsibilities of the Organization

The organization should:

- Conduct cybersecurity awareness training.
- Implement Multi-Factor Authentication (MFA).
- Use secure email filtering.
- Deploy anti-phishing solutions.
- Monitor suspicious login activities.
- Enforce strong password policies.
- Regularly perform phishing simulation exercises.

Responsibilities of the Employee

The employee should:

- Verify suspicious emails.
- Never click unknown links.
- Check sender email addresses carefully.
- Report suspicious emails immediately.
- Use strong passwords.
- Follow company security policies.

Technical Measures

- Multi-Factor Authentication (MFA)
- Secure Email Gateway
- SPF
- DKIM
- DMARC
- Endpoint Detection and Response (EDR)
- SIEM monitoring
- Password managers

Organizational Measures

- Cybersecurity awareness programs.
- Regular employee training.

- Incident response plan.
- Security audits.
- Access control policies.
- Periodic phishing simulations.

Phishing Attack Flow

Attacker



Fake Email



Employee



Clicks Fake Link



Enters Password



Attacker Gets Credentials



Company Network

Prevention Diagram

Employee



Cyber Awareness



Strong Password + MFA



▼
Email Filter + Antivirus

|

▼
Secure Company Network

Conclusion

This incident demonstrates that human error is often exploited by attackers. Combining employee awareness with strong technical controls significantly reduces the success of phishing attacks.

4. Student Exploits Banking Vulnerability Without Permission

Introduction

Discovering vulnerabilities is valuable for improving cybersecurity. However, exploiting vulnerabilities without authorization—even with good intentions—is generally considered unauthorized hacking. Ethical hacking differs from unauthorized hacking because it always requires permission.

Ethical Evaluation

The student's actions are **partially ethical but professionally incorrect**.

Positive aspects:

- Intended to improve security.
- Reported the vulnerability.
- Did not seek financial gain.

Negative aspects:

- Exploited the vulnerability without permission.
- Accessed real customer information.
- Violated customer privacy.
- Exceeded ethical boundaries.

Therefore, the actions cannot be considered ethical hacking.

Ethical Hacking vs Unauthorized Hacking

Ethical Hacking

Written permission obtained

Legal activity

Defined scope

Protects systems

Follows responsible disclosure

Unauthorized Hacking

No permission obtained

Illegal activity

No defined scope

May expose systems to risk

May violate privacy

Applicable IT Act Provisions

Section 43

Unauthorized access to a computer system.

Section 66

Computer-related offences involving unauthorized access.

Section 66C

May apply if customer credentials or identities are misused.

Section 72

Accessing confidential customer information without authorization may violate confidentiality provisions.

Why the Bank Initiated Legal Action

The bank's decision is legally understandable because:

- Customer information was accessed.
- Banking systems require strict confidentiality.
- Unauthorized testing can violate banking regulations.
- Good intentions do not eliminate legal liability.

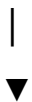
Proper Reporting Process Without a Bug Bounty Program

If no official disclosure policy exists, the student should:

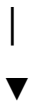
1. Verify the vulnerability without exploiting customer data.
2. Collect minimal non-sensitive evidence.
3. Document the technical details.
4. Contact the bank's security team confidentially.
5. Inform the bank through official communication channels.
6. Allow reasonable time for remediation.
7. Coordinate public disclosure only after the issue is fixed.
8. If necessary, report to appropriate cybersecurity authorities such as **CERT-In** if the organization is unresponsive.

Ethical Hacking Process

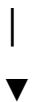
Permission



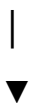
Testing



Find Vulnerability



Report to Organization



Issue Fixed

Unauthorized Hacking

No Permission

|



Exploit Vulnerability

|



Access Customer Data

|



Legal Action

Conclusion

Although the student intended to help, accessing customer information without permission made the activity unauthorized and legally risky. Ethical hacking always requires prior authorization and responsible disclosure. Following established reporting procedures protects both researchers and organizations while improving overall cybersecurity.